

EA-0030 - AQELYN Engineering Archive

AQELYN - EA-0030 Engineering Archive

IS-030 - AQELYN Software Supply Chain Security & SBOM Intelligence Engine

****Archive ID:**** EA-0030

****Implementation Specification:**** IS-030

****Component:**** AQELYN Software Supply Chain Security & SBOM Intelligence Engine

****Project:**** AQELYN

****System Type:**** Cyber Security Operating Environment

****Status:**** COMPLETE

****Repository Impact:**** No top-level repository structure changes

****Breaking Changes:**** None

****Predecessor Archives:**** EA-0001 through EA-0029

****Next Specification:**** IS-031 - AQELYN Data Security Posture Management (DSPM) Intelligence Engine

Document Control

| Field | Value |

---|---

| Document | Engineering Archive EA-0030 |

| Specification | IS-030 - AQELYN Software Supply Chain Security & SBOM Intelligence Engine |

| Publication Format | Markdown, PDF, HTML, ZIP |

| Source of Truth | MD/EA-0030.md |

| Archive Rule | Implementation Specification -> Engineering Archive -> Continue |

| Repository Rule | Fixed repository structure; no redesign |

| Completion State | IS-030 complete; EA-0030 generated |

1. Engineering Context

AQELYN is being built as a modular Cyber Security Operating Environment.

Completed engineering archive chain:

| Engineering Archive | Implementation Specification | Component |

---|---|---

| EA-0001 | IS-001 | AQELYN Kernel |

| EA-0002 | IS-002 | Universal Object Model |

| EA-0003 | IS-003 | AQELYN Event Bus |

| EA-0004 | IS-004 | AQELYN Evidence Engine |

- | EA-0005 | IS-005 | AQELYN Knowledge Graph |
- | EA-0006 | IS-006 | AQELYN Trust Engine |
- | EA-0007 | IS-007 | AQELYN Mission Engine |
- | EA-0008 | IS-008 | AQELYN Workflow Engine |
- | EA-0009 | IS-009 | AQELYN Policy Engine |
- | EA-0010 | IS-010 | AQELYN Compliance & Governance Engine |
- | EA-0011 | IS-011 | AQELYN Identity & Access Governance Engine |
- | EA-0012 | IS-012 | AQELYN Asset & Configuration Governance Engine |
- | EA-0013 | IS-013 | AQELYN Risk Intelligence Engine |
- | EA-0014 | IS-014 | AQELYN Threat Intelligence Fusion Engine |
- | EA-0015 | IS-015 | AQELYN Security Operations Engine |
- | EA-0016 | IS-016 | AQELYN Digital Forensics Engine |
- | EA-0017 | IS-017 | AQELYN Threat Detection & Analytics Engine |
- | EA-0018 | IS-018 | AQELYN Automated Response & Orchestration Engine |
- | EA-0019 | IS-019 | AQELYN Security Data Lake & Telemetry Platform |
- | EA-0020 | IS-020 | AQELYN AI Decision Intelligence Engine |
- | EA-0021 | IS-021 | AQELYN Predictive Analytics & Forecasting Engine |
- | EA-0022 | IS-022 | AQELYN Executive Intelligence & Strategic Reporting Engine |
- | EA-0023 | IS-023 | AQELYN Threat Exposure & Attack Surface Management Engine |
- | EA-0024 | IS-024 | AQELYN Vulnerability Intelligence & Prioritization Engine |
- | EA-0025 | IS-025 | AQELYN Cyber Asset Discovery & Inventory Intelligence Engine |
- | EA-0026 | IS-026 | AQELYN Configuration Compliance & Drift Intelligence Engine |
- | EA-0027 | IS-027 | AQELYN Identity Threat Detection & Behavioral Analytics Engine |
- | EA-0028 | IS-028 | AQELYN Cloud Security Posture Management Intelligence Engine |
- | EA-0029 | IS-029 | AQELYN SaaS Security Posture Management Intelligence Engine |
- | EA-0030 | IS-030 | AQELYN Software Supply Chain Security & SBOM Intelligence Engine |

The fixed repository structure remains:

```
AQELYN/  
■■■ archive/  
■■■ blueprint/  
■■■ docs/  
■■■ src/  
■■■ tests/  
■■■ tools/  
■■■ build/  
■■■ releases/  
■■■ scripts/  
■■■ assets/  
■■■ examples/  
■■■ plugins/  
■■■ sdk/  
■■■ api/  
■■■ README.md
```

2. IS-030 Specification Identity

Specification ID: IS-030
Name: AQELYN Software Supply Chain Security & SBOM Intelligence Engine
Engineering Archive Target: EA-0030
Project: AQELYN
System Type: Cyber Security Operating Environment
Status: Complete
Predecessor: IS-029 - AQELYN SaaS Security Posture Management Intelligence Engine

3. Purpose

The AQELYN Software Supply Chain Security & SBOM Intelligence Engine provides continuous visibility into software supply chains by discovering software components, generating and validating Software Bills of Materials (SBOMs), analyzing package dependencies, detecting vulnerable or malicious components, verifying software provenance, and monitoring supply chain risk across enterprise applications.

The engine correlates SBOM data, package metadata, vulnerability intelligence, code-signing information, artifact repositories, dependency graphs, and software provenance using explainable AI and policy-driven analytics.

It answers:

```
Which software components are deployed?  
Which applications contain vulnerable dependencies?  
Which software artifacts lack trusted provenance?  
Which third-party libraries violate policy?  
Which software packages require immediate remediation?  
Can every supply chain assessment be explained and audited?
```

4. Mission

The engine shall provide:

```
Continuous software inventory  
SBOM generation and validation  
Dependency graph analysis  
Software provenance verification  
Supply chain risk scoring  
Policy compliance validation  
Mission-aware software risk reporting  
Executive supply chain summaries  
Continuous reassessment  
Software governance support
```

5. Scope

5.1 In Scope

```
Software Bills of Materials (SBOM)  
Open source dependencies  
Commercial software packages  
Container images  
OCI artifacts  
Build artifacts  
Package repositories  
Digital signatures  
Software provenance  
Dependency relationships
```

5.2 Out of Scope

```
Source code development  
CI/CD pipeline orchestration  
Application performance monitoring  
License procurement  
Financial software asset management
```

6. Dependencies

IS-030 depends on:

- IS-001 AQELYN Kernel
- IS-002 Universal Object Model
- IS-003 AQELYN Event Bus
- IS-004 AQELYN Evidence Engine
- IS-005 AQELYN Knowledge Graph
- IS-006 AQELYN Trust Engine
- IS-007 AQELYN Mission Engine
- IS-008 AQELYN Workflow Engine
- IS-009 AQELYN Policy Engine
- IS-010 AQELYN Compliance & Governance Engine
- IS-011 Identity & Access Governance Engine
- IS-012 Asset & Configuration Governance Engine
- IS-013 Risk Intelligence Engine
- IS-014 Threat Intelligence Fusion Engine
- IS-015 Security Operations Engine
- IS-016 Digital Forensics Engine
- IS-017 Threat Detection & Analytics Engine
- IS-018 Automated Response & Orchestration Engine
- IS-019 Security Data Lake & Telemetry Platform
- IS-020 AI Decision Intelligence Engine
- IS-021 Predictive Analytics & Forecasting Engine
- IS-022 Executive Intelligence & Strategic Reporting Engine
- IS-023 Threat Exposure & Attack Surface Management Engine
- IS-024 Vulnerability Intelligence & Prioritization Engine
- IS-025 Cyber Asset Discovery & Inventory Intelligence Engine
- IS-026 Configuration Compliance & Drift Intelligence Engine
- IS-027 Identity Threat Detection & Behavioral Analytics Engine
- IS-028 Cloud Security Posture Management Intelligence Engine
- IS-029 SaaS Security Posture Management Intelligence Engine

7. High-Level Architecture

AQELYN Software Supply Chain Security Engine



- Software Inventory Engine
- SBOM Intelligence Engine
- Dependency Analysis Engine
- Provenance Verification Engine
- Supply Chain Compliance Engine
- Supply Chain Risk Engine
- Knowledge Graph Connector
- Security Data Lake Connector
- AI Decision Connector
- Executive Reporting Connector
- Event Publisher

8. Functional Requirements

FR-030-001 - Software Inventory

The engine shall continuously discover and catalog:

- Applications
- Libraries
- Packages
- Dependencies
- Container images
- Runtime artifacts
- Repositories
- Software versions

FR-030-002 - SBOM Intelligence

Continuously generate, import, validate, and compare:

- CycloneDX SBOMs
- SPDX SBOMs
- Dependency graphs
- Component inventories
- Package metadata
- Version history
- Integrity metadata
- SBOM drift

FR-030-003 - Supply Chain Risk Detection

Detect:

- Known vulnerable packages
- Malicious dependencies
- Unsigned artifacts
- Compromised repositories
- Untrusted publishers
- Dependency confusion
- Typosquatting
- Policy violations

FR-030-004 - Explainable Supply Chain Intelligence

Every assessment shall include:

- Evidence references
- Confidence indicators
- Policy rationale
- Dependency lineage
- Historical context
- Risk explanation

FR-030-005 - Governance

Support:

- SBOM governance
- Approval workflows
- Software policy validation
- Auditability
- Executive review

FR-030-006 - Event Publication

Publish standardized events:

- software.component.discovered
- sbom.generated
- sbom.validated
- dependency.risk.detected
- software.provenance.verified
- software.remediation.recommended

9. Non-Functional Requirements

The engine shall provide:

- Continuous assessment
- Enterprise scalability
- Low-latency dependency analysis
- Explainability
- Auditability
- Repository stability
- Backward compatibility

10. Core Supply Chain Assessment Lifecycle

```
Software Component Discovered
↓
SBOM Generated / Imported
↓
Dependency Analysis
↓
Provenance Verification
↓
Risk Assessment
↓
Policy Validation
↓
Continuous Monitoring
```

11. Internal Component Architecture

The AQELYN Software Supply Chain Security & SBOM Intelligence Engine is implemented as a modular software supply chain intelligence platform integrated with the AQELYN Kernel, Knowledge Graph, Security Data Lake, Vulnerability Intelligence Engine, Cyber Asset Discovery Engine, Risk Intelligence Engine, AI Decision Intelligence Engine, Executive Intelligence Engine, and Security Operations Engine.

```
AQELYN Software Supply Chain Security Engine
■
■■■ Software Inventory Engine
■■■ SBOM Intelligence Engine
■■■ Dependency Analysis Engine
■■■ Provenance Verification Engine
■■■ Supply Chain Compliance Engine
■■■ Supply Chain Risk Engine
■■■ Knowledge Graph Connector
■■■ Security Data Lake Connector
■■■ AI Decision Connector
■■■ Executive Reporting Connector
■■■ Event Publisher
```

12. Component Specifications

12.1 Software Inventory Engine

Continuously discovers software assets and package metadata.

Capabilities:

```
Application inventory
Package discovery
Library identification
Version tracking
Repository discovery
Artifact cataloging
```

12.2 SBOM Intelligence Engine

Generates, imports, validates, and compares Software Bills of Materials.

Supports:

```
CycloneDX support
SPDX support
SBOM validation
SBOM normalization
SBOM comparison
```

SBOM drift analysis

12.3 Dependency Analysis Engine

Analyzes software dependency relationships.

Produces:

Dependency graphs
Transitive dependency analysis
Dependency lineage
Package trust evaluation
Dependency risk scoring

12.4 Provenance Verification Engine

Verifies software origin and integrity.

Produces:

Digital signature validation
Artifact provenance
Publisher verification
Repository trust evaluation
Supply chain integrity scoring

12.5 Supply Chain Compliance Engine

Validates software components against enterprise policy.

Supports:

Compliance scoring
Policy validation
Regulatory mapping
License policy verification
Audit evidence

12.6 Supply Chain Risk Engine

Calculates software supply chain risk.

Produces:

Supply chain risk score
Mission impact
Business impact
Threat likelihood
Remediation priority

13. Universal Object Model Extensions

13.1 SoftwareComponent

SoftwareComponent:
component_id
name
version
publisher

13.2 SBOMDocument

```
SBOMDocument:  
sbom_id  
format  
generated_at  
integrity_hash
```

13.3 DependencyRelationship

```
DependencyRelationship:  
dependency_id  
parent_component  
child_component  
relationship_type
```

13.4 ProvenanceRecord

```
ProvenanceRecord:  
provenance_id  
publisher  
signature_status  
trust_score
```

14. Knowledge Graph Integration

Relationships:

```
Application  
↓  
contains  
↓  
SoftwareComponent  
  
SoftwareComponent  
↓  
depends_on  
↓  
SoftwareComponent  
  
SoftwareComponent  
↓  
verified_by  
↓  
ProvenanceRecord  
  
DependencyRelationship  
↓  
contributes_to  
↓  
SupplyChainRisk
```

15. Event Bus Integration

15.1 Software Inventory Events

```
software.component.discovered  
software.component.updated  
software.component.removed
```

15.2 SBOM Events

```
sbom.generated  
sbom.imported  
sbom.validated  
sbom.updated
```


15.3 Dependency Events

```
dependency.risk.detected  
dependency.graph.updated
```

15.4 Provenance Events

```
software.provenance.verified  
software.signature.failed  
software.remediation.recommended
```

16. Security Data Lake Integration

Consumes:

```
SBOM repositories  
Package metadata  
Artifact repositories  
Build metadata  
Container registries  
Software telemetry
```

17. AI Decision Intelligence Integration

Consumes:

```
Supply chain risk scores  
Dependency intelligence  
Compliance trends  
Remediation recommendations  
Confidence indicators
```

18. Risk & Threat Integration

Consumes:

```
Threat intelligence  
Known vulnerabilities  
Mission impact  
Business criticality  
Package reputation  
Repository trust intelligence
```

19. Compliance Integration

Supports:

```
Software governance  
SBOM governance  
Policy validation  
Audit evidence  
Executive reporting
```

20. Public APIs

20.1 Software Inventory API

```
GET /software/components
GET /software/components/{id}
```

20.2 SBOM API

```
GET /sboms
GET /sboms/{id}
POST /sboms/import
```

20.3 Dependency API

```
GET /dependencies
GET /dependencies/{id}
```

20.4 Provenance API

```
GET /provenance
POST /provenance/verify
```

21. Repository Impact

Implementation shall use the approved repository structure.

```
AQELYN/
  ■■■ src/
  ■ ■■■ software_supply_chain/
  ■■■ tests/
  ■ ■■■ software_supply_chain/
  ■■■ docs/
  ■ ■■■ software_supply_chain/
  ■■■ api/
  ■ ■■■ software_supply_chain/
  ■■■ archive/
```

No top-level repository modifications are permitted.

22. Security Architecture

The AQELYN Software Supply Chain Security & SBOM Intelligence Engine is the trusted subsystem responsible for continuously discovering software components, validating SBOMs, verifying software provenance, detecting dependency risks, assessing software supply chain integrity, and governing enterprise software security intelligence.

Every software supply chain assessment shall be:

```
Explainable
Evidence-backed
Policy-governed
Dependency-aware
Risk-aware
Mission-aware
Fully auditable
Continuously reassessed
```

22.1 Security Principles

```
Zero Trust
Defense in Depth
Least Privilege
Continuous Supply Chain Assessment
Secure by Design
Policy Enforcement
```

Explainable Supply Chain Intelligence
Continuous Monitoring

22.2 Authorization Model

Supported operational roles:

Software Supply Chain Administrator
Application Security Engineer
DevSecOps Engineer
Security Administrator
SOC Analyst
Compliance Officer
Mission Owner
Executive Reviewer

All software supply chain assessments and remediation decisions shall be governed through the AQELYN Policy Engine.

22.3 SBOM Integrity

SBOM records shall maintain:

Unique SBOM identifier
Format
Generation source
Integrity hash
Component references
Dependency references
Provenance references
Audit trail

SBOM history shall be append-only.

22.4 Provenance Integrity

Provenance records shall maintain:

Provenance identifier
Publisher
Signature status
Repository reference
Trust score
Verification timestamp
Evidence references
Audit record

No artifact shall be considered trusted without provenance metadata and validation state.

23. Software Supply Chain Lifecycle

23.1 Assessment Lifecycle

Software Component Discovered
↓
SBOM Generated / Imported
↓
Dependency Analysis
↓
Provenance Verification
↓
Risk Assessment
↓
Continuous Monitoring

23.2 Remediation Lifecycle

```
graph TD; A[Issue Detected] --> B[Risk Prioritized]; B --> C[Remediation Generated]; C --> D[Approval Granted]; D --> E[Remediation Applied]; E --> F[Validation Completed];
```

23.3 Audit Lifecycle

```
graph TD; A[Assessment Created] --> B[Evidence Linked]; B --> C[Policy Validated]; C --> D[Audit Stored];
```

24. Continuous Supply Chain Operations

The engine continuously evaluates:

```
graph TD; A[Software components] --> B[Package repositories]; B --> C[Dependency graphs]; C --> D[SBOM documents]; D --> E[Container images]; E --> F[Artifact integrity]; F --> G[Software provenance]; G --> H[Supply chain compliance];
```

25. Performance Requirements

The engine shall support:

```
graph TD; A[Continuous assessment] --> B[Low-latency dependency analysis]; B --> C[Enterprise-scale software inventories]; C --> D[Concurrent SBOM validation]; D --> E[High availability]; E --> F[Continuous operation];
```

26. Scalability Requirements

The engine shall scale to support:

```
graph TD; A[Global enterprises] --> B[Millions of software components]; B --> C[Large dependency graphs]; C --> D[Multiple artifact repositories]; D --> E[Distributed software assessments]; E --> F[Long-term SBOM history];
```

27. Audit Requirements

Every software supply chain operation shall generate immutable audit records.

Audit events include:

- Software component discovered
- SBOM generated
- SBOM validated
- Dependency risk detected
- Provenance verified
- Remediation completed

28. Failure Handling

28.1 Discovery Failure

- Discovery retried
- Failure recorded
- Administrator notified

28.2 SBOM Validation Failure

- Validation retried
- Previous assessment retained
- Audit generated

28.3 Provenance Verification Failure

- Verification repeated
- Manual review initiated
- Audit recorded

28.4 Policy Failure

- Artifact approval blocked
- Policy violation recorded
- Manual approval required

29. Testing Strategy

29.1 Unit Testing

Validate:

- Software Inventory Engine
- SBOM Intelligence Engine
- Dependency Analysis Engine
- Provenance Verification Engine
- Supply Chain Compliance Engine
- Supply Chain Risk Engine

29.2 Integration Testing

Verify interaction with:

- Kernel
- Knowledge Graph
- Security Data Lake
- Vulnerability Intelligence Engine
- Cyber Asset Discovery Engine
- Risk Intelligence Engine
- AI Decision Engine
- Executive Reporting Engine

Security Operations Engine

29.3 System Testing

Validate:

- Software inventory
- SBOM generation
- Dependency analysis
- Provenance verification
- Risk scoring
- Audit generation

29.4 Security Testing

Verify:

- Authorization
- Policy enforcement
- Explainability
- Audit logging
- Supply chain assessment integrity

29.5 Regression Testing

Verify IS-001 through IS-029 remain unaffected.

30. Acceptance Criteria

IS-030 is complete when:

- Software Inventory Engine implemented
- SBOM Intelligence Engine implemented
- Dependency Analysis Engine implemented
- Provenance Verification Engine implemented
- Supply Chain Compliance Engine implemented
- Supply Chain Risk Engine implemented
- Repository unchanged
- Testing documented

31. Repository Validation

Repository structure remains unchanged.

```
AQELYN/  
■■■ src/software_supply_chain/  
■■■ tests/software_supply_chain/  
■■■ docs/software_supply_chain/  
■■■ api/software_supply_chain/  
■■■ archive/
```

No top-level repository modifications are permitted.

32. Engineering Summary

IS-030 introduces the AQELYN Software Supply Chain Security & SBOM Intelligence Engine, providing enterprise-scale software inventory, SBOM generation and validation, dependency intelligence, software provenance verification,

explainable software supply chain risk scoring, and continuous software governance.

Major capabilities include:

- Software Inventory
- SBOM Generation & Validation
- Dependency Graph Analysis
- Software Provenance Verification
- Supply Chain Compliance Validation
- Supply Chain Risk Scoring
- Mission-Aware Software Risk Reporting
- Executive Supply Chain Reporting
- Continuous Supply Chain Monitoring
- Software Governance

The engine integrates with all previously completed AQELYN engines while preserving repository stability, modularity, and backward compatibility.

33. Specification Status

Specification ID : IS-030
Title : AQELYN Software Supply Chain Security & SBOM Intelligence Engine
Status : COMPLETE
Engineering Archive : READY FOR GENERATION
Next Artifact : EA-0030

34. EA-0030 Engineering Objective

The objective of IS-030 was to introduce a dedicated Software Supply Chain Security & SBOM Intelligence Engine that enables AQELYN to continuously discover software components, generate and validate SBOMs, analyze dependency graphs, verify provenance, detect software supply chain risk, validate policy compliance, and generate remediation recommendations.

The engine extends AQELYN from SaaS posture management into software supply chain integrity and SBOM governance.

35. EA-0030 Engineering Summary

The implementation specification defines a modular subsystem responsible for:

- Software inventory
- SBOM intelligence
- Dependency graph analysis
- Software provenance verification
- Supply chain compliance validation
- Supply chain risk scoring
- SBOM governance
- Software remediation recommendations
- Knowledge Graph integration
- Security Data Lake integration
- Risk and threat intelligence integration
- AI Decision integration
- Executive reporting integration
- Event publishing

36. Major Engineering Decisions

36.1 Decision 1 - Dedicated Software Supply Chain Engine

Software supply chain security responsibilities are implemented as a standalone engine rather than embedded in vulnerability intelligence, asset inventory, or application security.

Rationale:

Clear separation of software provenance and dependency intelligence.
Independent lifecycle and governance.
Better support for SBOM validation, dependency graphs, and artifact trust.
Improved traceability for supply chain posture assessments.

36.2 Decision 2 - SBOM Documents Are First-Class Objects

SBOM documents are modeled as governed, versioned, evidence-backed objects.

Benefits:

SBOM generation and import can be audited.
Component lineage becomes traceable.
SBOM drift can be detected over time.

36.3 Decision 3 - Provenance Is Required for Trust

Software provenance and signature verification are required for trust decisions.

Benefits:

Unsigned artifacts can be identified.
Publisher trust can be evaluated.
Repository compromise risk can be reduced.

36.4 Decision 4 - Dependency Relationships Are Graph-Based

Dependency relationships are represented as graph entities.

Benefits:

Transitive dependencies can be analyzed.
Risk propagation becomes visible.
Applications can be linked to vulnerable components.

36.5 Decision 5 - Event-Driven Software Supply Chain Lifecycle

Software discovery, SBOM, dependency, provenance, risk, and remediation events are published through the AQELYN Event Bus.

Examples include:

```
software.component.discovered
software.component.updated
software.component.removed
sbom.generated
sbom.imported
sbom.validated
sbom.updated
dependency.risk.detected
dependency.graph.updated
software.provenance.verified
software.signature.failed
software.remediation.recommended
```

36.6 Decision 6 - Universal Object Model Extension

New domain objects introduced include:


```

SoftwareComponent
SBOMDocument
DependencyRelationship
ProvenanceRecord

```

37. Architectural Integration Summary

| Engine | Integration |

|--|--|

| IS-001 Kernel | Runtime lifecycle and service registration |

| IS-002 Universal Object Model | Software, SBOM, dependency, provenance objects |

| IS-003 Event Bus | Software inventory, SBOM, dependency, provenance events |

| IS-004 Evidence Engine | Evidence references and supply chain support |

| IS-005 Knowledge Graph | Application, component, dependency, provenance, risk relationships |

| IS-006 Trust Engine | Data confidence and artifact trust |

| IS-007 Mission Engine | Mission-aware software risk prioritization |

| IS-008 Workflow Engine | Remediation and approval workflows |

| IS-009 Policy Engine | Software policy validation and artifact approval |

| IS-010 Compliance Engine | SBOM governance and regulatory mapping |

| IS-013 Risk Intelligence Engine | Risk scoring and business impact |

| IS-014 Threat Intelligence Engine | Package reputation and threat intelligence |

| IS-015 Security Operations Engine | Supply chain investigations and SOC workflows |

| IS-019 Security Data Lake | SBOM, package, artifact, and repository telemetry |

| IS-020 AI Decision Engine | Remediation recommendations and confidence scoring |

| IS-022 Executive Reporting Engine | Executive supply chain summaries |

| IS-024 Vulnerability Intelligence Engine | Vulnerability context for components |

| IS-025 Cyber Asset Discovery Engine | Application and software inventory context |

No existing engine required redesign.

38. Repository Impact Summary

Repository structure remains unchanged.

Implementation is expected within existing project directories, including:

```

AQELYN/
■■■ src/software_supply_chain/
■■■ tests/software_supply_chain/
■■■ api/software_supply_chain/
■■■ docs/software_supply_chain/
■■■ archive/

```

No top-level directories were added, removed, or renamed.

39. Security Impact Summary

The specification introduces software-supply-chain-specific security controls:

- Policy-governed software assessments
- Evidence-backed SBOM validation
- Dependency graph risk analysis
- Software provenance verification
- Digital signature validation
- Artifact trust scoring
- Supply chain risk scoring
- SBOM audit trail
- Role-authorized supply chain administration

No reduction in the security posture of existing components was identified.

40. Capabilities Added

The engine enables AQELYN to support:

- Continuous software inventory
- SBOM generation and validation
- Dependency graph analysis
- Software provenance verification
- Supply chain risk scoring
- Policy compliance validation
- Mission-aware software risk reporting
- Executive supply chain summaries
- Continuous reassessment
- Software governance support

41. Risks Identified

| Risk | Mitigation |

|---|---|

| Missing SBOM coverage | Continuous SBOM generation and import |

| Vulnerable transitive dependencies | Dependency graph analysis |

| Untrusted artifacts | Provenance verification and signature validation |

| Repository compromise | Repository trust intelligence |

| Malicious dependencies | Threat intelligence and package reputation |

| SBOM drift | SBOM comparison and drift analysis |

| Weak governance | Policy validation and approval workflows |

| Poor auditability | Evidence-backed records and immutable audit events |

No critical architectural risks were identified that require redesign.

42. Verification Summary

The specification defines verification for:

- Unit testing
- Integration testing
- System testing
- Security testing
- Regression testing

Acceptance criteria cover software inventory, SBOM intelligence, dependency analysis, provenance verification, supply chain compliance, supply chain risk, repository validation, and testing documentation.

43. Engineering Principles Confirmed

The implementation complies with established AQELYN principles:

- Modular architecture
- Event-driven communication
- Immutable evidence references
- Traceability
- Explainability
- Security by design
- Repository stability
- Backward compatibility
- Governance-before-archive discipline

44. Dependencies

Required:

- EA-0001 through EA-0029
- IS-001 through IS-030

Enables:

- IS-031 and subsequent data security posture, resilience, privacy, and enterprise security intelligence components

45. Completion Record

- Engineering Archive : EA-0030
- Implementation Specification : IS-030
- Title : AQELYN Software Supply Chain Security & SBOM Intelligence Engine
- Engineering Status : COMPLETE
- Repository Status : UNCHANGED
- Architecture Status : EXTENDED
- Backward Compatibility : MAINTAINED

46. Archive Index Update

- EA-0001 IS-001 AQELYN Kernel
- EA-0002 IS-002 Universal Object Model
- EA-0003 IS-003 AQELYN Event Bus
- EA-0004 IS-004 AQELYN Evidence Engine
- EA-0005 IS-005 AQELYN Knowledge Graph
- EA-0006 IS-006 AQELYN Trust Engine
- EA-0007 IS-007 AQELYN Mission Engine
- EA-0008 IS-008 AQELYN Workflow Engine
- EA-0009 IS-009 AQELYN Policy Engine
- EA-0010 IS-010 AQELYN Compliance & Governance Engine
- EA-0011 IS-011 AQELYN Identity & Access Governance Engine
- EA-0012 IS-012 AQELYN Asset & Configuration Governance Engine
- EA-0013 IS-013 AQELYN Risk Intelligence Engine
- EA-0014 IS-014 AQELYN Threat Intelligence Fusion Engine
- EA-0015 IS-015 AQELYN Security Operations Engine
- EA-0016 IS-016 AQELYN Digital Forensics Engine
- EA-0017 IS-017 AQELYN Threat Detection & Analytics Engine
- EA-0018 IS-018 AQELYN Automated Response & Orchestration Engine
- EA-0019 IS-019 AQELYN Security Data Lake & Telemetry Platform
- EA-0020 IS-020 AQELYN AI Decision Intelligence Engine
- EA-0021 IS-021 AQELYN Predictive Analytics & Forecasting Engine
- EA-0022 IS-022 AQELYN Executive Intelligence & Strategic Reporting Engine
- EA-0023 IS-023 AQELYN Threat Exposure & Attack Surface Management Engine
- EA-0024 IS-024 AQELYN Vulnerability Intelligence & Prioritization Engine
- EA-0025 IS-025 AQELYN Cyber Asset Discovery & Inventory Intelligence Engine
- EA-0026 IS-026 AQELYN Configuration Compliance & Drift Intelligence Engine
- EA-0027 IS-027 AQELYN Identity Threat Detection & Behavioral Analytics Engine

EA-0028 IS-028 AQELYN Cloud Security Posture Management Intelligence Engine
EA-0029 IS-029 AQELYN SaaS Security Posture Management Intelligence Engine
EA-0030 IS-030 AQELYN Software Supply Chain Security & SBOM Intelligence Engine

47. Engineering Phase Status

Completed Engineering Archives : EA-0001 through EA-0030

Current Status:
EA-0030 COMPLETE

Next Implementation Specification:
IS-031 - AQELYN Data Security Posture Management Intelligence Engine

48. Engineering Archive Publication Standard

EA-0030 follows the AQELYN Engineering Archive Publication Standard.

Required package structure:

```
EA-xxxx/  
■  
■ ■ ■ diagrams/  
■ ■ ■ ■ Architecture.svg  
■ ■ ■ ■ Component.svg  
■ ■ ■ ■ Workflow.svg  
■ ■ ■ ■ EventFlow.svg  
■ ■ ■ ■ Integration.svg  
■  
■ ■ ■ examples/  
■ ■ ■ ■ example_*.md  
■  
■ ■ ■ HTML/  
■ ■ ■ ■ index.html  
■ ■ ■ ■ styles.css  
■ ■ ■ ■ assets/  
■  
■ ■ ■ images/  
■  
■ ■ ■ journal/  
■ ■ ■ ■ Engineering_Journal.md  
■  
■ ■ ■ manifest/  
■ ■ ■ ■ manifest.json  
■  
■ ■ ■ MD/  
■ ■ ■ ■ EA-xxxx.md  
■  
■ ■ ■ PDF/  
■ ■ ■ ■ EA-xxxx.pdf  
■  
■ ■ ■ requirements/  
■ ■ ■ ■ Requirements_Matrix.md  
■  
■ ■ ■ traceability/  
■ ■ ■ ■ Traceability_Matrix.md  
■  
■ ■ ■ README.md
```

The master Markdown is the source of truth. The PDF and HTML are generated from the same master Markdown and must not omit sections.

49. Requirements Matrix

| Requirement ID | Requirement | Evidence in Archive | Status |

---	---	---	---
FR-030-001	Continuously inventory software	Sections 8, 12, 23	Complete
FR-030-002	Generate and validate SBOMs	Sections 8, 12, 23	Complete
FR-030-003	Detect supply chain risks	Sections 8, 12, 23	Complete
FR-030-004	Provide explainable supply chain intelligence	Sections 8, 22, 36	Complete
FR-030-005	Support governance	Sections 8, 22, 23	Complete
FR-030-006	Publish supply chain events	Sections 8, 15, 36	Complete
NFR-030-001	Continuous assessment	Sections 9, 24	Complete
NFR-030-002	Enterprise scalability	Sections 9, 25, 26	Complete
NFR-030-003	Low-latency dependency analysis	Sections 9, 25	Complete
NFR-030-004	Explainability	Sections 9, 22, 36	Complete
NFR-030-005	Auditability	Sections 9, 27, 39	Complete
NFR-030-006	Repository stability	Sections 21, 31, 38	Complete

50. Traceability Matrix

Source	Target	Relationship
---	---	---
IS-030 Purpose	EA-0030 Objective	Defines why the engine exists
Software Inventory Engine	FR-030-001	Discovers software components
SBOM Intelligence Engine	FR-030-002	Generates, imports, validates, and compares SBOMs
Dependency Analysis Engine	FR-030-003	Detects dependency risk
Provenance Verification Engine	FR-030-003	Verifies artifacts and publishers
Supply Chain Compliance Engine	Governance and compliance	Maps software posture to controls
Supply Chain Risk Engine	Risk scoring	Calculates supply chain security risk
Event Publisher	FR-030-006	Publishes supply chain events
Security Data Lake Integration	Software telemetry	Supplies SBOM, package, artifact, repository data
AI Decision Integration	Remediation recommendations	Supplies confidence and recommendations
Risk & Threat Integration	Threat context	Supplies vulnerabilities, reputation, and trust intelligence
Compliance Integration	Governance and audit	Supports SBOM governance and evidence
Repository Validation	Repository Standard	Confirms no top-level redesign

51. Engineering Journal

Journal Entry - EA-0030

EA-0030 was created to archive completion of IS-030 - AQELYN Software Supply Chain Security & SBOM Intelligence Engine.

The archive records the expansion of AQELYN into software supply chain and SBOM intelligence. IS-030 defines the structure needed to discover software components, generate and validate SBOMs, analyze dependency graphs, verify provenance, detect supply chain risks, validate software policy, calculate supply chain risk, and publish software supply chain events.

The engineering design preserves the fixed AQELYN repository structure and maintains backward compatibility with previously completed engines.

Lessons Learned

Software supply chain security must be modeled separately from vulnerability intelligence. Vulnerability intelligence identifies vulnerable components; software supply chain intelligence validates component provenance, dependency lineage, SBOM integrity, and artifact trust.

Governance Note

EA-0030 follows the master-document publication workflow. The Markdown file is the authoritative source, and PDF/HTML representations are generated from the same content.

52. Examples

52.1 Example Software Component

```
component_id: SWC-0001
name: example-library
version: 2.4.1
publisher: trusted_vendor
package_type: npm
```

52.2 Example SBOM Document

```
sbom_id: SBOM-2001
format: CycloneDX
generated_at: 2026-07-07T12:00:00Z
integrity_hash: sha256:example
component_count: 186
```

52.3 Example Provenance Record

```
provenance_id: PROV-3001
publisher: trusted_vendor
signature_status: valid
trust_score: 0.92
```

52.4 Example Software Supply Chain Event

```
{
  "event_type": "dependency.risk.detected",
  "component_id": "SWC-0001",
  "risk_score": 84,
  "source_engine": "aqelyn_software_supply_chain_security_sbom_intelligence_engine"
}
```

53. Manifest Summary

Archive contents include:

```
README.md
MD/EA-0030.md
PDF/EA-0030.pdf
HTML/index.html
HTML/styles.css
manifest/manifest.json
requirements/Requirements_Matrix.md
traceability/Traceability_Matrix.md
journal/Engineering_Journal.md
diagrams/Architecture.svg
diagrams/Component.svg
diagrams/Workflow.svg
diagrams/EventFlow.svg
```

```
diagrams/Integration.svg  
examples/example_software_supply_chain.md
```

54. Final Archive Statement

EA-0030 is the Engineering Archive for IS-030 - AQELYN Software Supply Chain Security & SBOM Intelligence Engine.

It records the completed specification, the architectural decisions, the integration model, the repository impact, the risk posture, verification requirements, acceptance criteria, archive index update, and the engineering publication standard.

```
EA-0030 COMPLETE  
IS-030 COMPLETE  
NEXT: IS-031
```